



UNIVERSIDAD TECNOLÓGICA DE PANAMÁ

FACULTAD DE INGENIERÍA DE

SISTEMAS COMPUTACIONALES

DEPARTAMENTO DE SISTEMAS DE

INFORMACIÓN CONTROL Y EVALUACIÓN DE RECURSOS INFORMATICOS



Tema:

**Monitoreo permanente del cliente: Convergencia tecnológica entre la Ley 23 de 2015 y la
Ley 81 de Protección de Datos Personales en Panamá
SAGAF (UAF)**

Carrera:

Desarrollo y Gestión de Software

Materia:

Ingeniería de software Aplicada IV

Integrantes:

Yini Pan 4-828-621

Yoel Samaniego 8-1023-1507

Eric Ruiz 8-1016-2092

Gabriel González 8-1017-1568

Facilitador:

María Félix Mosquera

Grupo: 1GS241

Índice de contenido

I. Investigación del Tema.....	1
1.1 Problemática.....	1
1.2 Propuesta de solución	1
1.3 Marco Teórico Referencial.....	1
II. Diseño del Formulario.....	2
2.1. Descripción del formulario.....	2
2.2. Diseño visual del formulario	2
2.3. Explicación de secciones del formulario.....	3
III. Requerimientos y propuesta del software	3
3.1. Nombre y Descripción del sistema propuesto.	4
3.2. Requisitos funcionales	4
3.3. Requisitos no funcionales.....	5
IV. Diagramas UML (Modificar).....	6
4.1. Diagrama de Casos de Uso.....	6
4.2. Especificación de casos de uso	8
4.3 Criterios de Aceptación.....	14
4.4 Diagrama de clases.	16
V. Pruebas Diseñadas	17
5.1. Pruebas Alfa	17
5.2. Pruebas Beta	19
5.3. Pruebas UX.....	20
VI. Matriz de Defectos	22
6.1 Descripción de defectos detectados	22
6.2 Impacto de los defectos.....	23
Bibliografía	24

I. Investigación del Tema

1.1 Problemática

Actualmente, los sujetos obligados financieros y no financieros deben aplicar debida diligencia, monitoreo continuo y reporte de operaciones sospechosas conforme a la Ley 23 de 2015 (Asamblea Nacional de Panamá, 2015). Sin embargo, la gestión de los Reportes de Operaciones Sospechosas (ROS) requiere una plataforma más estructurada que permita recibir, validar, organizar, priorizar y analizar la información reportada de forma segura.

Las deficiencias del sistema actual son:

- **Registro y análisis fragmentado:** los ROS pueden provenir de bancos, inmobiliarias y otros sujetos obligados, cada uno con documentación y datos distintos, lo que dificulta la estandarización del análisis.
- **Validación limitada de partes involucradas:** en operaciones bancarias se requiere diferenciar claramente entre quien realiza la transacción y el beneficiario, permitiendo verificar ambos por cédula sin exponer datos personales innecesarios.
- **Carga documental poco controlada:** los documentos de sustento suelen gestionarse de forma general, cuando cada archivo solicitado debe tener un contenedor individual para identificar cuáles fueron cargados y cuáles faltan.
- **Riesgo de exposición de datos personales:** si una cédula ya existe en registros internos, el sistema no debe completar automáticamente datos sensibles en el portal público; solo debe mostrar el nombre para corroboración.
- **Necesidad de trazabilidad interna:** la UAF requiere una vista interna clara para revisar ROS, verificar documentos, priorizar casos, auditar acciones y solicitar subsanaciones.

1.2 Propuesta de solución

Se propone el desarrollo de SAGAF, un sistema dividido en dos componentes principales:

- **Portal público para sujetos obligados:** hospedado por la UAF, posiblemente mediante infraestructura de la AIG, donde bancos, inmobiliarias y otros sujetos obligados ingresan con credenciales institucionales y MFA para registrar ROS.
- **Sistema interno para la UAF:** utilizado por analistas, supervisores y administradores para consultar, clasificar, analizar, auditar y dar seguimiento a los ROS recibidos.

La solución contempla:

- Formularios dinámicos según el tipo de sujeto obligado.
- Para bancos, separación entre la persona que realiza la transacción y el beneficiario, ambos verificables por cédula.
- Para inmobiliarias, campos relacionados con el bien inmueble, forma de pago, comprador y sustento de fondos.
- Validación de cédula/RUC sin exponer datos personales completos; solo se muestra el nombre para corroboración.
- Carga individual de cada documento solicitado, permitiendo saber qué archivo fue entregado y cuál está pendiente.
- Vista interna UAF con bandeja de ROS, resumen del caso, riesgo, documentos, auditoría y acciones de subsanación.

1.3 Marco Teórico Referencial

Ley 23 de 2015: Prevención de Blanqueo de Capitales

Es la piedra angular del proyecto. Esta ley establece la obligación de identificar al beneficiario final y realizar una debida diligencia basada en riesgo. Su objetivo es evitar que los sistemas financieros y no financieros sean utilizados para el blanqueo de capitales y el financiamiento del terrorismo.

Monitoreo Permanente (Artículos de la Ley 23)

El monitoreo permanente no es una revisión estática, sino un examen continuo del perfil transaccional del cliente. El software debe garantizar que el volumen de fondos y la naturaleza de las operaciones sean coherentes con la actividad económica declarada por el usuario. (Asamblea Nacional de Panamá, 2015)

Ley 81 de 2019: Protección de Datos Personales

Esta ley dicta las reglas del juego para el tratamiento de datos en Panamá. Establece que todo tratamiento de datos requiere el consentimiento del titular o una excepción legal (como la prevención de delitos), pero siempre bajo principios de lealtad, finalidad y proporcionalidad. Define los datos sensibles y los derechos ARCO (Acceso, Rectificación, Cancelación y Oposición) (Asamblea Nacional de Panamá, 2019).

Privacidad desde el Diseño (Privacy by Design)

Es el enfoque técnico del software. Implica que la protección de datos no es un "parche" que se pone al final, sino que está integrada en el código desde la fase de arquitectura.

- **Minimización de datos:** El software solo recolectará lo estrictamente necesario para el monitoreo.
- **Seguridad Extremo a Extremo:** Los datos viajan y se almacenan cifrados.

- **Transparencia:** El sistema genera registros de auditoría (logs) inalterables para saber exactamente quién accedió a qué información y por qué.

II. Diseño del Formulario

2.1. Descripción del formulario

Propósito:

El formulario tiene como propósito permitir que los sujetos obligados registren ROS de forma segura, estructurada y adaptada a su sector. El sistema permite capturar información general del reporte, partes involucradas, operación sospechosa y documentos de sustento.

El formulario no debe funcionar como una página pública abierta, sino como un portal autenticado con MFA para sujetos obligados registrados.

Base legal:

El sistema se fundamenta en la Ley 23 de 2015 de Panamá, que establece obligaciones de prevención de blanqueo de capitales mediante debida diligencia y monitoreo continuo de clientes, y en la Ley 81 de 2019 sobre protección de datos personales. También se apoya en estándares del GAFI sobre enfoque basado en riesgo y monitoreo continuo del cliente durante toda la relación comercial (Grupo de Acción Financiera Internacional, 2023).

Justificación de campos:

Los campos se organizan según el tipo de sujeto obligado:

- **Datos del ROS:** entidad reportante, oficial de cumplimiento, fecha de detección y descripción del caso.
- **Validación de personas:** cédula, pasaporte o RUC. Si existe coincidencia, solo se muestra el nombre y se bloquean los demás campos sensibles.
- **Banco:** separación entre ordenante/persona que realiza la transacción y beneficiario.
- **Inmobiliaria:** datos del comprador, bien inmueble, forma de pago, ubicación, valor y procedencia de fondos.
- **Operación sospechosa:** monto, jurisdicción, producto o bien involucrado, señal de alerta y narrativa.
- **Sustento documental:** cada documento requerido posee su propio contenedor de carga.

2.2. Diseño visual del formulario

SG

SAGAF

Portal público • Sistema interno UAF

VISTAS

Vista interna UAF

Portal sujetos obligados

DEMO RÁPIDA

Registrar ROS Banco

Registrar ROS Inmobiliaria

Esta versión corrige el flujo: cada documento tiene su propio contenedor de carga, la cédula se valida sin exponer datos personales y la vista UAF es más limpia para análisis y priorización.

SISTEMA INTERNO DE LA UAF

Analista UAF

MFA activo • Acceso por caso

Bandeja de análisis de Reportes de Operaciones Sospechosas

Vista enfocada en revisar ROS recibidos, priorizar riesgo, verificar sustentos, solicitar subsanaciones y mantener trazabilidad completa sin saturar al analista.

Nuevos ROS

42

Hoy

Alto riesgo

11

Atención prioritaria

Con sustento incompleto

8

Subsanación

Vinculos detectados

23

Validar relación

Bandeja de ROS

Priorizada por riesgo, estado y completitud documental.

Actualizado

Buscar ROS, entidad, documento

Todos

ROS-2026-000248

Alto

Banco Nacional Demo

Cliente: ***-***-482

Estado: En análisis - Sustento: 21/24 documentos

ROS-2026-000249

Medio

Inmobiliaria Istmo Demo

Comprador: ***-***-095

Estado: Revisión documental - Sustento: 12/17 documentos

ROS-2026-000250

Vinculado

Banco Nacional Demo

Sociedad: RUC ***-77

Estado: Escalado - Posible beneficiario relacionado

ROS-2026-000248 • Banco

Riesgo alto

Reporte recibido desde el portal público. Datos sensibles enmascarados por defecto.

Resumen

Riesgo

Documentos

Auditoria

SUJETO OBLIGADO

Banco Nacional Demo

TIPO

Banco • Persona Juridica

CLIENTE

RUC ***-77

MONTO REPORTADO

USD 985,000

ESTADO

En análisis

COMPLETITUD

21 de 24 documentos

RESUMEN NARRATIVO

Movimientos incompatibles con el perfil declarado, transferencias internacionales y relación con beneficiario final reportado previamente. El expediente contiene estados de cuenta, Swift, ACH y comunicaciones internas de descarte.

Abrir expediente completo

Solicitar subsanación

Validar análisis

Ver relaciones

SG

SAGAF

Portal público + Sistema interno UAF

VISTAS

Vista interna UAF

Portal sujetos obligados

DEMO RÁPIDA

Registrar ROS Banco

Registrar ROS Inmobiliaria

Esta versión corrige el flujo: cada documento tiene su propio contenedor de carga, la cédula se valida sin exponer datos personales y la vista UAF es más limpia para análisis y priorización.

PORTAL PÚBLICO HOSPEDADO POR LA UAF / AIG

Registro seguro de ROS para sujetos obligados

El sujeto obligado ingresa con credenciales institucionales y MFA. Luego registra el ROS mediante un formulario dinámico según su sector, adjuntando cada documento en su propio contenedor.

SO

Portal de Reporte

MFA - Evidencia individualizada

Ingreso institucional

MFA requerido

Simulación de autenticación segura para demostración.

El portal no debe exponer información personal ya registrada. Si una cédula/RUC existe, el sistema solo informa la coincidencia y bloquea los campos del cliente.

Tipo de sujeto obligado

Banco

Usuario institucional

cumplimiento@entidad.cor

Contraseña

Código MFA

Ingrese código OTP de 6 dígitos

Cargar demo

Validar acceso

1 Credenciales

Usuario institucional autorizado.

2 MFA

OTP o app autenticadora.

3 Formulario sectorial

Campos y documentos según Banco o Inmobiliaria.

Formulario ROS - Banco

Banco

Complete los datos requeridos y adjunte la evidencia individual correspondiente.

1. Datos generales del ROS

Entidad reportante

Banco Nacional Demo

Fecha de detección

mm/dd/aaaa

Oficial de cumplimiento

Nombre completo

Correo institucional

correo@entidad.com

2. Validación de personas relacionadas

Tipo de cliente

Persona Natural

Para reportes bancarios, valide por separado la persona que realiza la transacción y el beneficiario. En el portal público solo se muestra el nombre para corroboración.

Persona que realiza la transacción

Cédula del ordenante

Verificar

Nombre encontrado

Solo se mostrará el nombre si existe

Beneficiario

Cédula del beneficiario

Verificar

Nombre encontrado

Solo se mostrará el nombre si existe

3. Información de la operación sospechosa

Monto aproximado

Jurisdicción / ubicación

2.3. Explicación de secciones del formulario

Sección de Recepción y Registro de ROS

Permite registrar ROS desde el portal público autenticado. El sistema genera un identificador único, registra la entidad reportante, fecha, usuario responsable y datos principales del caso.

Validaciones: MFA activo, campos obligatorios, formato de cédula/RUC, monto válido, descripción del caso y documentos mínimos según sector.

Sección de Perfil del Cliente Reportado

Permite validar la identidad del cliente o parte involucrada. Si la cédula/RUC existe, el sistema solo muestra el nombre para corroboración y bloquea los demás campos para evitar exposición de datos personales.

En bancos, esta sección se divide en:

- Persona que realiza la transacción.
- Beneficiario.

Ambos se verifican por cédula y solo muestran el nombre.

Sección de Operaciones Sospechosas

Registra la información de la operación: monto, tipo, jurisdicción, producto bancario o bien inmueble, señal de alerta y narrativa del caso.

Validaciones: monto numérico, fechas coherentes, señal de alerta seleccionada y descripción suficiente.

Sección de Búsqueda y Filtrado Inteligente

En la vista interna UAF, permite buscar ROS por número, entidad reportante, tipo de sujeto obligado, riesgo, estado, documento, cliente enmascarado o completitud documental.

Validaciones: permisos por rol, enmascaramiento de datos y auditoría de consultas.

Sección de Clasificación y Priorización de Casos

Permite a la UAF clasificar el riesgo del ROS, revisar alertas, validar documentos y solicitar subsanaciones.

Validaciones: justificación obligatoria para cambios de estado, permisos por rol y registro en auditoría.

Sección de Reportes e Inteligencia Financiera

Permite generar reportes internos sobre ROS recibidos, sectores, riesgos, documentos pendientes, tiempos de atención y patrones detectados.

Validaciones: permisos, datos agregados cuando aplique, auditoría y control de exportación.

III. Requerimientos y propuesta del software

SAGAF será un sistema de apoyo a la UAF para recibir, organizar, analizar y dar seguimiento a ROS enviados por sujetos obligados financieros y no financieros. El sistema se compone de un portal público autenticado y una vista interna para la UAF.

El sistema no sustituye el análisis humano ni determina culpabilidad. Su función es mejorar la recepción, trazabilidad, priorización, control documental y análisis de los ROS. (Unidad de Análisis Financiero, 2018).

3.1. Nombre y Descripción del sistema propuesto.

El sistema se llamará SAGAF, siglas de Sistema Automatizado de Gestión de Análisis Financiero de la Unidad de Análisis Financiero (UAF). El cual comprende diversos componentes como:

Funcionalidades Principales

- **Portal público para sujetos obligados:**

Permite que bancos, inmobiliarias y otros sujetos obligados ingresen mediante credenciales institucionales y autenticación multifactor. Desde este portal podrán registrar ROS, completar los datos requeridos según su sector y adjuntar la documentación de sustento correspondiente.

- **Formulario dinámico por tipo de sujeto obligado:**

El sistema adapta los campos del formulario según el tipo de entidad reportante. Para bancos, muestra campos relacionados con transacciones, cuentas, productos bancarios, ordenante y beneficiario. Para inmobiliarias, muestra campos sobre comprador, bien inmueble, forma de pago, valor del bien y procedencia de fondos.

- **Validación segura de identidad:**

El sistema permite verificar cédula, pasaporte o RUC de las partes involucradas. Si existe coincidencia, únicamente muestra el nombre para que el reportante corrobore la identidad, sin exponer dirección, historial, actividad económica u otros datos sensibles.

- **Gestión diferenciada para bancos:**

En los reportes bancarios, el formulario separa claramente a la persona que realiza la transacción y al beneficiario. Ambos pueden ser validados por cédula, y el sistema mantiene esta información vinculada al ROS para facilitar el análisis posterior de la UAF.

- **Gestión específica para inmobiliarias:**

En los reportes inmobiliarios, el sistema permite registrar información del comprador, ubicación del bien, valor de venta, forma de pago, financiamiento bancario, avalúos y sustento de procedencia de fondos.

- **Carga documental individualizada:**

Cada documento requerido tiene su propio contenedor de carga. Esto permite identificar con claridad qué documentos fueron entregados, cuáles están pendientes y cuáles requieren revisión o subsanación.

- **Bandeja interna de ROS para la UAF:**

La UAF cuenta con una vista interna donde puede revisar los ROS recibidos, filtrar por entidad reportante, riesgo, estado, sector, monto, jurisdicción y completitud documental.

- **Análisis y priorización de casos:**

El sistema permite clasificar los ROS por nivel de riesgo bajo, medio o alto. Esta clasificación sirve como apoyo al análisis, pero no sustituye la evaluación del analista o supervisor autorizado.

- **Gestión documental y subsanación:**

Los analistas de la UAF pueden revisar los documentos cargados, identificar archivos faltantes, marcar observaciones y solicitar subsanación al sujeto obligado sin exponer información innecesaria.

- **Trazabilidad y auditoría:**

Cada acción relevante queda registrada: inicio de sesión, validación MFA, envío de ROS, verificación de identidad, carga de documentos, consulta de expedientes, cambios de estado, clasificación de riesgo y solicitudes de subsanación.

- **Reportes internos e inteligencia financiera:**

El sistema permite generar reportes sobre cantidad de ROS recibidos, sujetos obligados reportantes, sectores, niveles de riesgo, documentos pendientes, tiempos de atención y patrones básicos de comportamiento.

3.2. Requisitos funcionales

Los requisitos funcionales describen las capacidades que el SAGAF debe ejecutar para cumplir con los objetivos operativos de la UAF y el marco normativo de la Ley 23 de 2015, la Ley 81 de 2019 y las recomendaciones internacionales del GAFI.

- **RF-01 — Recepción, Registro y Gestión de ROS**

El sistema debe permitir que los sujetos obligados registren ROS desde un portal autenticado con MFA. Cada reporte debe recibir un número único, fecha de recepción, entidad reportante, oficial de cumplimiento, tipo de sujeto obligado, descripción del caso y documentos adjuntos.

El formulario debe adaptarse al sector. Para bancos debe incluir ordenante/persona que realiza la transacción y beneficiario. Para inmobiliarias debe incluir comprador, bien inmueble, forma de pago y procedencia de fondos.

- **RF-02 — Búsqueda, Filtrado y Clasificación de Casos**

La vista interna UAF debe permitir buscar y filtrar ROS por número, entidad, tipo de sujeto obligado, estado, riesgo, documento, monto, jurisdicción y completitud documental.

El sistema debe permitir clasificar el riesgo como alto, medio o bajo, registrar justificación y mantener historial de cambios.

- **RF-03 — Trazabilidad y Auditoría**
El sistema debe registrar cada acción relevante: inicio de sesión, validación MFA, verificación de cédula, envío de ROS, carga de archivos, consulta de expediente, cambio de estado, clasificación de riesgo y solicitud de subsanación.
Cada registro debe incluir usuario, rol, fecha, hora, acción realizada, resultado y expediente relacionado.
- **RF-04 — Generación de Reportes e Inteligencia Financiera**
El sistema debe generar reportes internos sobre cantidad de ROS recibidos, sectores reportantes, casos por riesgo, documentos pendientes, tiempos de atención y patrones básicos.
Los reportes deben respetar permisos, enmascaramiento y auditoría.
- **RF-05 — Control de Acceso por Roles**
El sistema debe manejar roles diferenciados:
 - Sujeto obligado reportante.
 - Analista UAF.
 - Supervisor UAF.
 - Administrador del sistema.

El acceso debe requerir MFA. Los sujetos obligados solo pueden ver y gestionar sus propios reportes. La UAF puede analizar los ROS según permisos internos.
- **RF-06 — Validación segura de identidad**
El sistema debe permitir verificar cédula, pasaporte o RUC. Si existe coincidencia, solo debe mostrar el nombre de la persona o razón social para corroboración. No debe autocompletar dirección, actividad, contacto, historial ni otros datos sensibles.
En bancos, esta validación debe aplicarse por separado a:
 - Persona que realiza la transacción.
 - Beneficiario.
- **RF-07 — Carga documental individualizada**
El sistema debe mostrar un contenedor de carga por cada documento requerido según el sector.
Cada archivo debe quedar asociado al documento solicitado, indicando estado: pendiente, cargado, observado o validado.
Para bancos debe contemplar documentos de persona natural, persona jurídica y sustento transaccional. Para inmobiliarias debe contemplar sustento documental y operacional del bien inmueble.

3.3. Requisitos no funcionales

Los requisitos no funcionales definen los atributos de calidad y restricciones técnicas que el SAGAF debe cumplir para operar de forma segura, eficiente y sostenible en la infraestructura de la UAF.

- **RNF-01 — Seguridad y Privacidad de la Información**
El sistema debe proteger la información sensible de los ROS, sujetos obligados, clientes, beneficiarios, transacciones y documentos adjuntos mediante autenticación multifactor, cifrado, control de acceso por roles y enmascaramiento de datos.
En el portal público, el sistema no debe mostrar información personal completa de personas ya registradas. Si una cédula, pasaporte o RUC existe, solo debe mostrar el nombre para corroboración. Los demás datos deben permanecer ocultos y gestionarse únicamente desde la vista interna autorizada de la UAF.
- **RNF-02 — Control de Acceso y Roles**
El sistema debe separar claramente los permisos según el tipo de usuario. Los sujetos obligados solo podrán registrar, consultar y completar sus propios reportes. Los analistas UAF podrán revisar y clasificar los ROS asignados. Los supervisores podrán validar acciones críticas, revisar cierres y aprobar solicitudes relevantes.
El administrador del sistema podrá gestionar usuarios, roles y configuraciones, pero no debe tener acceso libre al contenido sensible de los ROS sin autorización y auditoría.
- **RNF-03 — Trazabilidad y Auditoría**
El sistema debe registrar todas las acciones importantes realizadas por los usuarios. Cada registro de auditoría debe incluir usuario, rol, fecha, hora, acción realizada, resultado, dirección IP y expediente relacionado.
La auditoría debe permitir reconstruir el ciclo de vida del ROS, desde su registro por el sujeto obligado hasta su revisión, clasificación, subsanación o cierre por parte de la UAF.
- **RNF-04 — Usabilidad e Interfaz Intuitiva**
La interfaz debe ser clara, ordenada y fácil de usar. El portal público debe guiar al sujeto obligado paso a paso para reducir errores al registrar el ROS. La vista interna de la UAF debe presentar la información de forma limpia, evitando saturar al analista con datos innecesarios.
Los formularios deben mostrar únicamente los campos necesarios según el tipo de sujeto obligado, ya sea banco, inmobiliaria u otro sector futuro.
- **RNF-05 — Gestión Documental Controlada**
El sistema debe permitir cargar documentos de forma individual, asociando cada archivo al requisito documental correspondiente. Cada documento debe tener un estado, como pendiente, cargado, observado o validado.

El sistema debe permitir identificar rápidamente documentos faltantes y generar solicitudes de subsanación. También debe registrar quién cargó, consultó o modificó cada documento.

- **RNF-06 — Integridad y Calidad de Datos**

El sistema debe validar formatos, campos obligatorios, montos, fechas, documentos requeridos y coherencia entre el tipo de sujeto obligado y la información registrada.

También debe evitar duplicidades innecesarias y permitir detectar coincidencias por cédula, RUC, beneficiario, cuenta, inmueble o entidad relacionada, sin revelar información sensible en el portal público.

- **RNF-07 — Rendimiento, Disponibilidad y Recuperación**

El sistema debe responder de forma eficiente durante el registro, consulta y análisis de ROS. Las acciones principales, como búsqueda, carga de formularios y consulta de expedientes, deben ejecutarse sin demoras excesivas.

La plataforma debe contar con respaldo de información, recuperación ante fallos y disponibilidad suficiente para que los sujetos obligados puedan enviar ROS y la UAF pueda revisarlos oportunamente.

IV. Diagramas UML

4.1. Diagrama de Casos de Uso

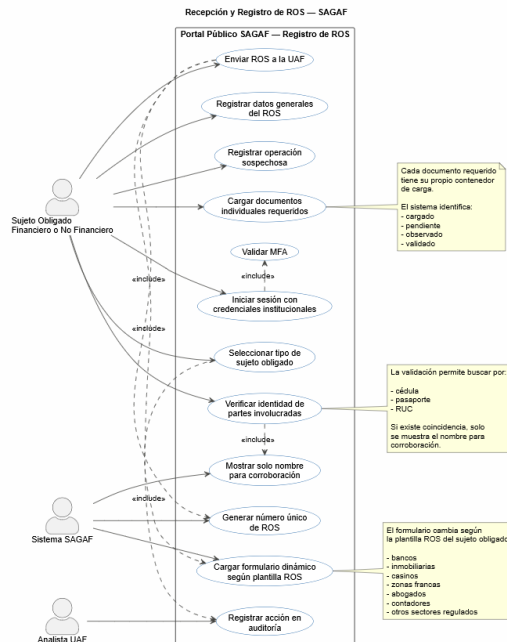


Figura 1 Caso de uso 1: Recepción y Registro de ROS

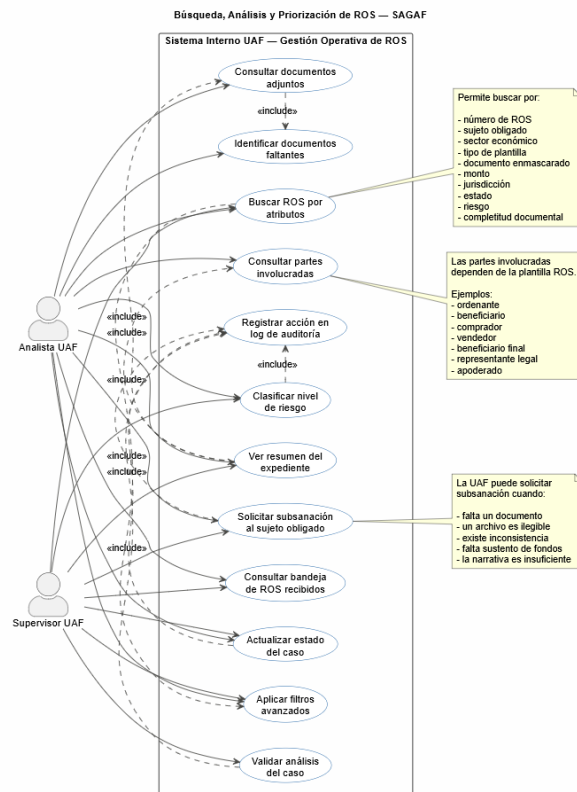


Figura 2 Caso de uso 2: Búsqueda, filtrado y clasificación de casos

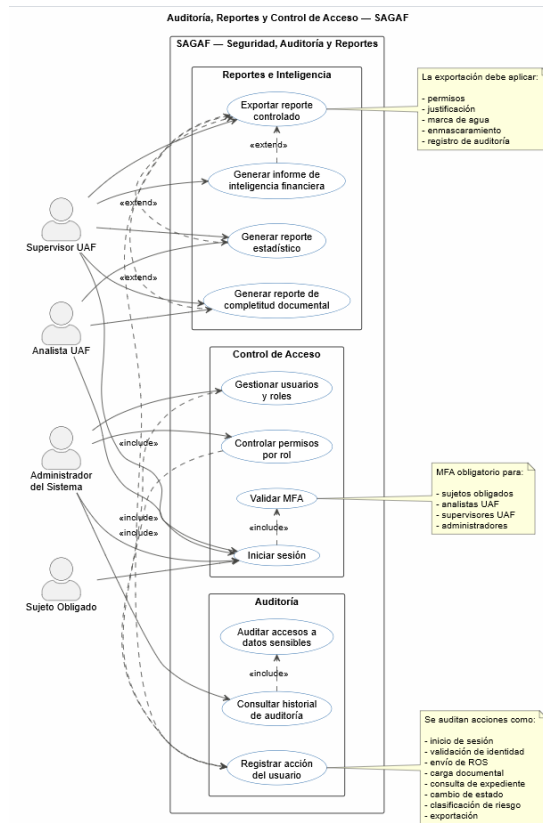


Figura 3 Caso de uso 3: Auditoría, Reportes y control de acceso

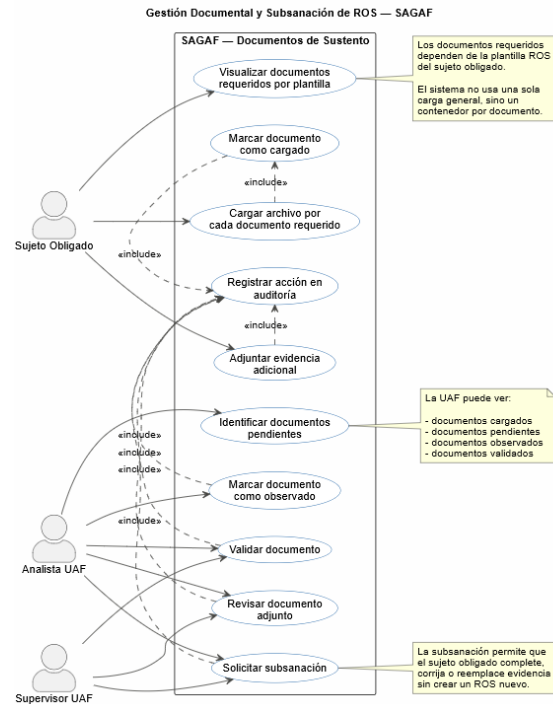


Figura 4 Caso de uso 4: Gestión Documental y Subsanación

4.2. Especificación de casos de uso

CU-01 — Recepción, Registro y Gestión de ROS

Actor(es) Principal(es): Sujeto Obligado

Breve Descripción:

Permite que un sujeto obligado financiero, no financiero o actividad profesional sujeta a supervisión registre un Reporte de Operación Sospechosa (ROS) desde el portal público de SAGAF. El sistema valida el acceso mediante credenciales institucionales y MFA, carga un formulario dinámico según la plantilla ROS correspondiente, permite verificar partes involucradas sin exponer datos sensibles, recibe documentos de sustento de forma individualizada y remite el reporte al sistema interno de la UAF para análisis.

Precondiciones:

El sujeto obligado se encuentra registrado y habilitado en SAGAF. El usuario cuenta con credenciales válidas, autenticación multifactor activa y permisos para registrar ROS. La plantilla correspondiente al tipo de sujeto obligado se encuentra configurada en el sistema.

Flujo Básico de Eventos:

- El sujeto obligado accede al portal público de SAGAF.
- El sistema solicita credenciales institucionales y autenticación multifactor.
- El usuario selecciona o confirma el tipo de sujeto obligado y sector económico al que pertenece.
- El sistema carga automáticamente el formulario dinámico según la plantilla ROS correspondiente.
- El usuario ingresa los datos generales del ROS, oficial de cumplimiento, fecha de detección y descripción inicial del caso.
- El usuario registra las partes involucradas según la plantilla aplicable.
- Si la plantilla lo requiere, el sistema permite verificar cédula, pasaporte o RUC de las partes involucradas.
- Si existe coincidencia, el sistema muestra únicamente el nombre para corroboración, sin revelar datos personales adicionales.
- El usuario registra la operación sospechosa, monto, jurisdicción, producto, servicio, bien o activo involucrado y señal de alerta.

- El sistema muestra los documentos requeridos por la plantilla, cada uno con su propio contenedor de carga.
- El usuario carga los documentos de sustento correspondientes y, si aplica, evidencia adicional.
- El sistema valida campos obligatorios, formato de archivos, completitud mínima y coherencia general del reporte.
- El usuario envía el ROS a la UAF.
- El sistema asigna un número único de ROS, registra fecha y hora de recepción y deja el reporte disponible en la bandeja interna de la UAF.
- El sistema registra la acción en el log de auditoría.

Flujos Alternos:

- **A1 — Fallo de autenticación:** El sistema deniega el acceso si las credenciales o el MFA son incorrectos.
- **A2 — Campos incompletos:** El sistema impide el envío del ROS e indica los campos faltantes o inválidos.
- **A3 — Documento faltante:** El sistema permite guardar el borrador o enviar el ROS con observación, según reglas de la UAF, marcando los documentos pendientes.
- **A4 — Archivo inválido:** El sistema rechaza archivos con formato no permitido, tamaño excesivo o error de carga.
- **A5 — Identidad existente:** Si una cédula, pasaporte o RUC ya existe, el sistema solo muestra el nombre para corroborar y bloquea los campos sensibles.
- **A6 — Posible duplicidad:** El sistema alerta si detecta un ROS similar enviado previamente por el mismo sujeto obligado.

Requerimientos Especiales:

- **RE-01:** El número único de ROS debe ser irrepetible.
- **RE-02:** La fecha y hora de recepción deben ser generadas automáticamente por el sistema.
- **RE-03:** El portal público no debe autocompletar datos sensibles de personas existentes.
- **RE-04:** Cada documento requerido debe cargarse en un contenedor individual asociado a su requisito documental.
- **RE-05:** Toda acción de registro, verificación, carga documental y envío debe quedar auditada.

Postcondiciones:

El ROS queda registrado con número único, sujeto obligado reportante, plantilla aplicada, partes involucradas, operación sospechosa, documentos cargados y estado inicial disponible para revisión de la UAF.

CU-02 — Búsqueda, Filtrado y Clasificación de Casos

Actor(es) Principal(es): Analista UAF / Supervisor UAF

Breve Descripción:

Permite a los usuarios internos de la UAF consultar la bandeja de ROS recibidos, aplicar filtros, revisar el resumen del expediente, clasificar riesgo, actualizar estados, identificar documentos faltantes y priorizar casos según el análisis realizado. El sistema debe mostrar una vista clara y ordenada que reduzca la carga visual y facilite la toma de decisiones.

Precondiciones:

Existen ROS registrados en el sistema. El usuario UAF ha iniciado sesión con MFA y posee permisos para consultar o gestionar expedientes.

Flujo Básico de Eventos:

- El usuario accede a la vista interna de SAGAF.
- El sistema muestra la bandeja de ROS recibidos con indicadores de riesgo, estado y completitud documental.
- El usuario realiza una búsqueda por número de ROS, sujeto obligado, sector, documento enmascarado, estado, riesgo, monto, jurisdicción o completitud documental.
- El sistema muestra los resultados permitidos según el rol del usuario.
- El usuario selecciona un ROS para abrir el resumen del expediente.
- El sistema muestra información general, partes involucradas, operación sospechosa, documentos, riesgo y auditoría.
- El analista revisa el caso y asigna o actualiza el nivel de riesgo.
- El usuario actualiza el estado del caso cuando corresponda.
- Si faltan documentos o existen inconsistencias, el usuario puede solicitar subsanación al sujeto obligado.
- El sistema registra cada acción en el log de auditoría.

Flujos Alternos:

- **A1 — Sin resultados:** El sistema informa que no existen registros con los criterios seleccionados.
- **A2 — Acceso restringido:** El sistema oculta o enmascara información que el usuario no está autorizado a consultar.
- **A3 — Riesgo alto:** El sistema resalta visualmente los casos de mayor prioridad.
- **A4 — Documentos incompletos:** El sistema muestra los documentos pendientes y habilita la solicitud de subsanación.
- **A5 — Coincidencias relevantes:** El sistema muestra posibles relaciones con otros ROS, sujetos obligados, beneficiarios, cuentas, inmuebles o identificadores.

Requerimientos Especiales:

- **RE-01:** Todo cambio de riesgo, estado o solicitud de subsanación debe quedar auditado.
- **RE-02:** La búsqueda debe respetar permisos, roles y niveles de confidencialidad.
- **RE-03:** El sistema no debe permitir cierres masivos automáticos sin revisión y autorización.
- **RE-04:** La vista interna debe priorizar claridad, reducción de ruido visual y acceso rápido a información crítica.

Postcondiciones:

El expediente queda actualizado con su estado, nivel de riesgo, observaciones o solicitudes de subsanación correspondientes. Las acciones quedan registradas en auditoría.

CU-03 — Trazabilidad y Auditoría del Sistema

Actor(es) Principal(es): Administrador del Sistema / Supervisor UAF / Auditor Interno

Breve Descripción:

Permite consultar y controlar el historial de acciones realizadas en SAGAF. La auditoría registra accesos, verificaciones de identidad, cargas documentales, envíos de ROS, consultas, cambios de estado, clasificación de riesgo, subsanaciones, exportaciones y administración de usuarios.

Precondiciones:

El usuario ha iniciado sesión con permisos para consultar auditoría. Existen eventos registrados en el sistema.

Flujo Básico de Eventos:

- El usuario accede al módulo de auditoría.
- El sistema muestra filtros por fecha, usuario, rol, sujeto obligado, número de ROS, acción, módulo y criticidad.
- El usuario aplica los criterios de búsqueda.
- El sistema muestra los eventos permitidos según el rol del usuario.
- Cada evento muestra usuario, rol, fecha, hora, acción, resultado, módulo afectado, expediente relacionado, IP y dispositivo cuando aplique.
- El sistema registra la consulta de auditoría como un nuevo evento.

Flujos Alternos:

- **A1 — Intento de modificación:** El sistema bloquea cualquier intento de editar el log y registra el evento.
- **A2 — Sin resultados:** El sistema indica que no existen eventos con los filtros aplicados.
- **A3 — Consulta no autorizada:** El sistema deniega el acceso y registra el intento.
- **A4 — Evento crítico:** El sistema destaca acciones sensibles como exportaciones, accesos denegados, cambios de rol o fallos de MFA.

Requerimientos Especiales:

- **RE-01:** El log debe ser de solo lectura para todos los perfiles.
- **RE-02:** Debe registrarse toda acción relevante del portal público y del sistema interno.
- **RE-03:** Los eventos deben permitir reconstruir el ciclo de vida del ROS.
- **RE-04:** Los intentos de acceso no autorizado deben considerarse eventos de seguridad.

Postcondiciones:

El usuario obtiene un historial filtrado de eventos. La consulta queda registrada en el log de auditoría.

CU-04 — Generación de Reportes e Inteligencia Financiera

Actor(es) Principal(es): Supervisor UAF / Analista UAF

Breve Descripción:

Permite generar reportes operativos y estratégicos sobre ROS recibidos, sujetos obligados, sectores, riesgo, documentos pendientes, tiempos de atención, jurisdicciones, tipologías y patrones básicos. Los reportes deben apoyar el análisis institucional sin exponer datos personales innecesarios.

Precondiciones:

Existen ROS registrados y el usuario cuenta con permisos para generar reportes.

Flujo Básico de Eventos:

- El usuario accede al módulo de reportes.
- El sistema muestra los tipos de reporte disponibles.
- El usuario selecciona reporte operativo, reporte documental, reporte estadístico o informe de inteligencia financiera.
- El usuario define parámetros como período, sector, tipo de sujeto obligado, riesgo, jurisdicción, estado, completitud documental o tipología.
- El sistema procesa la información.
- El sistema aplica anonimización o enmascaramiento cuando el reporte no requiere identificación individual.
- El usuario visualiza el reporte generado.
- Si posee permisos, el usuario exporta el reporte de forma controlada.
- El sistema registra la generación y exportación en auditoría.

Flujos Alternos:

- **A1 — Sin datos:** El sistema informa que no hay datos para los criterios seleccionados.
- **A2 — Información restringida:** El sistema limita o enmascara información no autorizada.
- **A3 — Exportación no autorizada:** El sistema bloquea la descarga y registra el intento.
- **A4 — Reporte pesado:** El sistema procesa el reporte en segundo plano o solicita reducir filtros.

Requerimientos Especiales:

- **RE-01:** Los reportes estratégicos deben priorizar datos agregados.
- **RE-02:** Toda exportación debe requerir permisos y quedar auditada.
- **RE-03:** Los reportes no deben revelar datos personales si no son necesarios para la finalidad del análisis.
- **RE-04:** Los reportes deben permitir evaluar calidad y completitud documental de los ROS.

Postcondiciones:

El reporte queda disponible para visualización o exportación autorizada. La acción queda registrada con usuario, fecha, parámetros y nivel de confidencialidad.

CU-05 — Control de Acceso y Gestión de Roles

Actor(es) Principal(es): Administrador del Sistema

Breve Descripción:

Permite administrar usuarios, roles, permisos y restricciones de acceso para sujetos obligados, analistas UAF, supervisores UAF, administradores y otros perfiles autorizados. El acceso debe protegerse mediante MFA y políticas de mínimo privilegio.

Precondiciones:

El administrador ha iniciado sesión con credenciales válidas y MFA.

Flujo Básico de Eventos:

- El administrador accede al módulo de usuarios y roles.
- El sistema muestra usuarios registrados y sus estados.
- El administrador crea, modifica, desactiva o consulta usuarios.
- El administrador asigna rol y permisos según el perfil del usuario.
- El sistema aplica restricciones de acceso por rol, entidad, módulo y expediente.
- El sistema exige MFA para el inicio de sesión.
- Si un usuario intenta acceder a información restringida, el sistema bloquea la acción.
- Todas las acciones quedan registradas en auditoría.

Flujos Alternos:

- **A1 — Fallo de autenticación:** El sistema deniega el acceso y registra el intento.
- **A2 — Cuenta desactivada:** El sistema impide el inicio de sesión.
- **A3 — Permiso insuficiente:** El sistema muestra acceso denegado y registra el evento.
- **A4 — Cambio de rol:** El sistema actualiza permisos y registra la modificación.

Requerimientos Especiales:

- **RE-01:** MFA debe ser obligatorio para todos los perfiles.
- **RE-02:** Los sujetos obligados solo pueden gestionar sus propios reportes.
- **RE-03:** El administrador no debe tener acceso libre al contenido sensible de los ROS sin justificación y auditoría.
- **RE-04:** Todo cambio de rol, permiso o estado de cuenta debe quedar registrado.

Postcondiciones:

El usuario queda habilitado, actualizado o desactivado según corresponda. Los permisos quedan aplicados y auditados.

CU-06 — Gestión de Sujetos Obligados

Actor(es) Principal(es): Administrador del Sistema / Supervisor UAF

Breve Descripción:

Permite registrar, clasificar y administrar sujetos obligados financieros, no financieros y actividades profesionales sujetas a supervisión. Cada sujeto obligado se asocia a su sector, organismo supervisor, usuarios autorizados y plantillas ROS correspondientes.

Precondiciones:

El usuario posee permisos administrativos o de supervisión. Se cuenta con información mínima del sujeto obligado.

Flujo Básico de Eventos:

- El usuario accede al módulo de sujetos obligados.
- El sistema muestra el formulario de registro o actualización.
- El usuario ingresa nombre, RUC o identificador, tipo de sujeto obligado, sector, organismo supervisor, estado y responsable de cumplimiento.
- El sistema valida campos obligatorios y posible duplicidad.
- El usuario asocia el sujeto obligado con una o varias plantillas ROS.
- El sistema registra o actualiza la información.
- El sistema deja habilitado al sujeto obligado para el uso del portal público, si corresponde.
- La acción queda registrada en auditoría.

Flujos Alternos:

- **A1 — Datos incompletos:** El sistema rechaza el registro e indica los campos faltantes.
- **A2 — Duplicidad:** El sistema muestra alerta si existe un sujeto obligado con el mismo identificador.
- **A3 — Sujeto obligado inactivo:** El sistema impide el envío de nuevos ROS hasta que sea habilitado.
- **A4 — Plantilla no asignada:** El sistema impide registrar ROS hasta asociar una plantilla válida.

Requerimientos Especiales:

- **RE-01:** Cada sujeto obligado debe tener tipo, sector, estado y plantilla asignada.
- **RE-02:** El sistema debe admitir nuevas plantillas por sector sin rediseñar toda la solución.
- **RE-03:** Toda creación, modificación o desactivación debe quedar auditada.

Postcondiciones:

El sujeto obligado queda registrado o actualizado, asociado a su sector, usuarios autorizados y plantillas de formulario ROS.

CU-07 — Vinculación Intersectorial de ROS, Clientes y Beneficiarios Finales

Actor(es) Principal(es): Analista UAF / Supervisor UAF

Breve Descripción:

Permite identificar y revisar relaciones entre ROS provenientes de distintos sujetos obligados cuando comparten personas, beneficiarios, representantes, documentos, sociedades, cuentas, inmuebles, direcciones u otros identificadores relevantes. La vinculación sirve como apoyo al análisis, pero debe ser confirmada por un usuario autorizado.

Precondiciones:

Existen ROS y datos relacionados registrados en SAGAF. El usuario tiene permisos de análisis.

Flujo Básico de Eventos:

- El usuario accede a la vista de detalle de un ROS o caso.
- El sistema consulta identificadores relacionados.
- El sistema muestra posibles coincidencias con otros ROS o expedientes.
- El usuario revisa las coincidencias sugeridas.
- El usuario confirma, descarta o deja pendiente la vinculación.
- Si confirma, el sistema registra la relación en el expediente.
- El sistema registra la acción en auditoría.

Flujos Alternos:

- **A1 — Sin coincidencias:** El sistema informa que no encontró relaciones relevantes.
- **A2 — Coincidencia descartada:** El sistema registra que el analista descartó la relación.
- **A3 — Información restringida:** El sistema muestra solo información autorizada o enmascarada.
- **A4 — Coincidencia de alto riesgo:** El sistema genera alerta interna para revisión prioritaria.

Requerimientos Especiales:

- **RE-01:** Las vinculaciones sugeridas no deben consolidarse automáticamente sin revisión humana.
- **RE-02:** Toda confirmación o descarte debe quedar auditado.
- **RE-03:** El sistema debe permitir relaciones por persona, beneficiario, sociedad, cuenta, inmueble, documento, dirección u otro identificador.

Postcondiciones:

Los ROS o casos quedan vinculados, descartados o pendientes de validación. La decisión queda registrada en auditoría.

CU-08 — Gestión Documental y Subsanción

Actor(es) Principal(es): Sujeto Obligado / Analista UAF / Supervisor UAF

Breve Descripción:

Permite gestionar los documentos requeridos por cada plantilla ROS. El sujeto obligado carga cada archivo en un contenedor individual, mientras la UAF revisa, valida, observa o solicita subsanación de documentos faltantes o incorrectos.

Precondiciones:

Existe una plantilla ROS configurada con documentos requeridos. El sujeto obligado o usuario UAF ha iniciado sesión con permisos válidos.

Flujo Básico de Eventos:

- El sistema muestra los documentos requeridos por la plantilla.
- El sujeto obligado carga cada archivo en su contenedor correspondiente.
- El sistema marca cada documento como cargado o pendiente.
- El sujeto obligado puede agregar evidencia adicional no catalogada.
- La UAF revisa los documentos desde la vista interna.
- El analista puede marcar documentos como validados, observados o pendientes de subsanación.
- Si existe inconsistencia, el analista solicita subsanación al sujeto obligado.
- El sujeto obligado corrige o reemplaza el archivo observado.
- El sistema registra cada acción en auditoría.

Flujos Alternos:

- **A1 — Archivo inválido:** El sistema rechaza el archivo por formato, tamaño o error de carga.
- **A2 — Documento ilegible:** La UAF marca el documento como observado.
- **A3 — Documento no aplica:** El sujeto obligado justifica por qué un documento no corresponde.
- **A4 — Subsanación vencida:** El sistema alerta a la UAF si la subsanación no se atiende en el plazo definido.

Requerimientos Especiales:

- **RE-01:** Cada documento debe tener estado: pendiente, cargado, observado, validado o no aplica.
- **RE-02:** Cada archivo debe estar asociado al ROS, al requisito documental y al usuario que lo cargó.
- **RE-03:** La descarga o consulta de documentos debe requerir permisos y quedar auditada.
- **RE-04:** El sistema debe permitir solicitar subsanación sin crear un nuevo ROS.

Postcondiciones:

Los documentos quedan organizados por requisito, con estado actualizado y trazabilidad completa. Las subsanaciones quedan registradas y asociadas al ROS.

4.3 Criterios de Aceptación

CU-01 — Recepción, Registro y Gestión de ROS

• CA-CU01-01

Dado que un sujeto obligado autenticado con MFA completa el formulario dinámico de ROS, cuando envía el reporte, entonces el sistema asigna un número único, registra fecha y hora, identifica la plantilla utilizada y coloca el ROS en la bandeja interna de la UAF.

• CA-CU01-02

Dado que el usuario intenta enviar un ROS con campos obligatorios incompletos, cuando el sistema valida el formulario, entonces bloquea el envío e indica los campos faltantes.

• CA-CU01-03

Dado que la plantilla requiere documentos de sustento, cuando el sujeto obligado carga archivos, entonces cada archivo queda asociado a su contenedor documental correspondiente.

- **CA-CU01-04**

Dado que una cédula, pasaporte o RUC ya existe, cuando el usuario realiza la verificación, entonces el sistema muestra únicamente el nombre para corroboración y no revela otros datos personales.

CU-02 — Búsqueda, Filtrado y Clasificación de Casos

- **CA-CU02-01**

Dado que el analista UAF consulta la bandeja interna, cuando aplica filtros por riesgo, estado, sector, sujeto obligado o completitud documental, entonces el sistema muestra únicamente los ROS que coinciden con los criterios y permisos del usuario.

- **CA-CU02-02**

Dado que el usuario actualiza el nivel de riesgo o estado de un ROS, cuando confirma la acción, entonces el sistema guarda el cambio y registra la acción en auditoría.

- **CA-CU02-03**

Dado que un ROS tiene documentos faltantes u observados, cuando el analista revisa el expediente, entonces el sistema permite generar solicitud de subsanación.

CU-03 — Trazabilidad y Auditoría del Sistema

- **CA-CU03-01**

Dado que cualquier usuario realiza una acción relevante, cuando el sistema la procesa, entonces registra usuario, rol, fecha, hora, acción, resultado y expediente relacionado.

- **CA-CU03-02**

Dado que un usuario intenta modificar el log, cuando el sistema detecta la acción, entonces bloquea el intento y lo registra como evento de seguridad.

CU-04 — Generación de Reportes e Inteligencia Financiera

- **CA-CU04-01**

Dado que el supervisor genera un reporte por sector, riesgo, período o tipo de sujeto obligado, cuando el sistema procesa la información, entonces presenta datos coherentes con los ROS registrados.

- **CA-CU04-02**

Dado que el reporte no requiere identificación individual, cuando se genera, entonces el sistema aplica enmascaramiento o anonimización.

- **CA-CU04-03**

Dado que un usuario intenta exportar un reporte sin permisos, cuando solicita la descarga, entonces el sistema bloquea la acción y registra el intento.

CU-05 — Control de Acceso y Gestión de Roles

- **CA-CU05-01**

Dado que un usuario inicia sesión, cuando ingresa credenciales válidas, entonces el sistema solicita MFA antes de permitir acceso.

- **CA-CU05-02**

Dado que un sujeto obligado accede al portal, cuando consulta reportes, entonces solo puede ver los reportes asociados a su propia entidad.

- **CA-CU05-03**

Dado que un usuario intenta acceder a información no autorizada, cuando el sistema valida permisos, entonces deniega el acceso y registra el evento.

CU-06 — Gestión de Sujetos Obligados

- **CA-CU06-01**

Dado que el administrador registra un sujeto obligado, cuando completa los datos requeridos, entonces el sistema almacena tipo, sector, estado, responsable de cumplimiento y plantilla ROS asociada.

- **CA-CU06-02**

Dado que un sujeto obligado no tiene plantilla asignada, cuando intenta registrar un ROS, entonces el sistema impide el envío hasta que se configure una plantilla válida.

CU-07 — Vinculación Intersectorial de ROS, Clientes y Beneficiarios Finales

- **CA-CU07-01**

Dado que existen ROS con identificadores coincidentes, cuando el sistema detecta relaciones, entonces muestra posibles vínculos para revisión humana.

- **CA-CU07-02**

Dado que el analista confirma o descarta una vinculación, cuando guarda la decisión, entonces el sistema registra la acción en auditoría.

CU-08 — Gestión Documental y Subsanación

- **CA-CU08-01**

Dado que una plantilla requiere documentos específicos, cuando el sujeto obligado abre el formulario, entonces el sistema muestra un contenedor de carga por cada documento requerido.

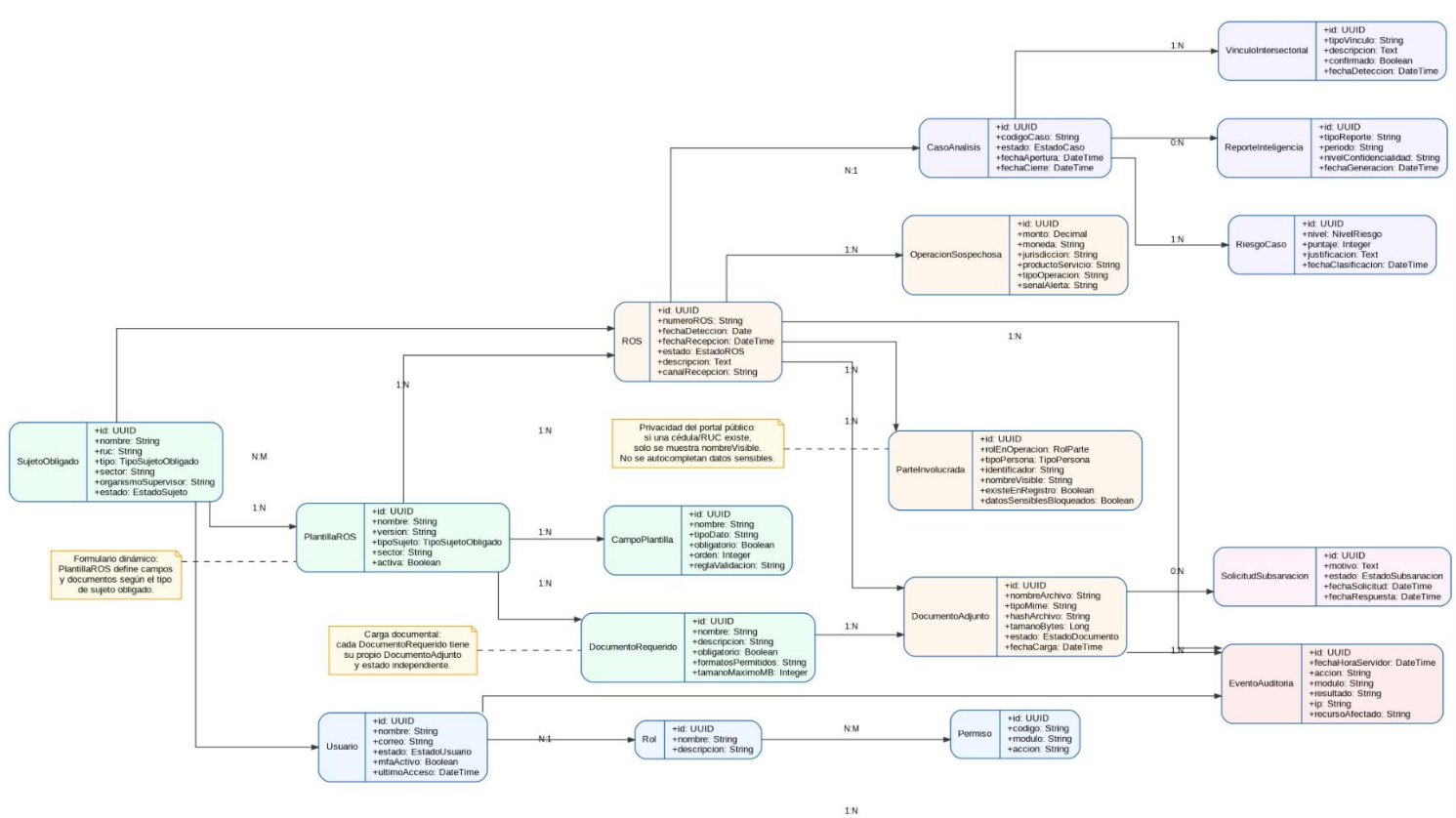
- **CA-CU08-02**

Dado que el usuario carga un archivo en un contenedor, cuando el sistema lo acepta, entonces cambia el estado del documento a “Cargado”.

- **CA-CU08-03**

Dado que un documento es observado por la UAF, cuando el analista solicita subsanación, entonces el sistema notifica al sujeto obligado y mantiene el ROS asociado.

4.4 Diagrama de clases.



V. Pruebas Diseñadas

5.1. Pruebas Alfa

Las pruebas alfa serán realizadas por el equipo técnico y funcional antes de exponer el sistema a usuarios finales. Su objetivo es detectar fallos críticos en el portal público, sistema interno UAF, validaciones, carga documental, seguridad y auditoría.

Objetivos de las pruebas alfa

- Verificar que el portal público permita registrar ROS mediante credenciales y MFA.
- Validar que el formulario cambie según la plantilla del sujeto obligado.
- Comprobar que cada documento requerido tenga su propio contenedor de carga.
- Validar que la verificación de cédula/RUC solo muestre el nombre y no exponga otros datos.
- Comprobar que los ROS enviados aparezcan en la bandeja interna de la UAF.
- Validar búsqueda, riesgo, documentos, auditoría y subsanación.
- Verificar controles de seguridad, roles y trazabilidad.

Alcance de las pruebas alfa

Portal público de sujetos obligados

Se verificará que:

- El inicio de sesión con MFA funcione correctamente.
- El sujeto obligado solo acceda a su propio entorno.
- El formulario dinámico cargue la plantilla correspondiente.
- Las partes involucradas puedan verificarse sin exponer datos sensibles.
- Los documentos se carguen en contenedores individuales.
- El sistema identifique documentos cargados, pendientes y observados.
- El ROS pueda guardarse como borrador o enviarse a la UAF.

Vista interna UAF

Se validará que:

- La bandeja de ROS muestre reportes recibidos.
- Los filtros funcionen correctamente.
- El resumen del expediente sea claro.
- El riesgo pueda clasificarse con justificación.
- Los documentos puedan revisarse, observarse o validarse.
- Se pueda solicitar subsanación al sujeto obligado.

Auditoría y trazabilidad

Se comprobará que:

- Inicio de sesión, MFA, envío de ROS, carga documental, cambios de estado y consultas queden registrados.
- El log no sea editable desde la interfaz.
- Los eventos críticos puedan filtrarse.

Seguridad y control de acceso

Se evaluará:

- MFA obligatorio.
- Restricción por rol.
- Bloqueo de acceso no autorizado.
- Enmascaramiento de datos sensibles.
- No exposición de datos personales en el portal público.

Tipos de pruebas alfa

Pruebas funcionales

Validan que cada caso de uso opere correctamente.

Ejemplos:

- Registro exitoso de ROS.
- Carga individual de documentos.
- Verificación de identidad mostrando solo el nombre.
- Clasificación de riesgo.
- Solicitud de subsanación.

Pruebas de integración

Validan comunicación entre módulos.

Ejemplos:

- Un ROS enviado desde el portal debe aparecer en la bandeja UAF.
- Un documento observado por la UAF debe quedar visible para subsanación.
- Una acción del usuario debe reflejarse en auditoría.

Pruebas de seguridad

Evalúan protección del sistema.

Ejemplos:

- Intento de acceso sin MFA.
- Consulta de ROS de otro sujeto obligado.
- Intento de visualizar datos personales no permitidos.
- Intento de modificar auditoría.

Pruebas de rendimiento

Evalúan tiempos de respuesta en carga de formularios, búsqueda, bandeja UAF y carga documental.

Resultados esperados

El sistema deberá:

- Registrar ROS correctamente.
- Mantener privacidad de datos personales.
- Controlar documentos por plantilla.
- Impedir accesos no autorizados.
- Registrar acciones en auditoría.
- Mantener una interfaz clara y estable.

5.2. Pruebas Beta

Las pruebas beta se realizarán con usuarios representativos del sistema: sujetos obligados, analistas UAF, supervisores y administradores. Su finalidad es validar el comportamiento del sistema en condiciones cercanas al uso real.

Objetivos de las pruebas beta

- Validar el flujo completo de registro de ROS desde el portal público.
- Confirmar que la vista interna UAF facilite análisis y priorización.
- Evaluar claridad del formulario dinámico por plantilla.
- Medir facilidad para cargar documentos individualmente.
- Validar que los sujetos obligados comprendan las solicitudes de subsanación.
- Detectar errores no identificados en pruebas alfa.

Participantes

- Usuarios representantes de sujetos obligados.
- Analistas UAF.
- Supervisores UAF.
- Administradores del sistema.
- Personal técnico autorizado.

Escenarios de prueba

Escenario 1 — Registro de ROS por sujeto obligado

El usuario deberá:

- Iniciar sesión con MFA.
- Completar formulario dinámico.
- Verificar partes involucradas.
- Cargar documentos requeridos.
- Enviar el ROS.

Escenario 2 — Revisión interna UAF

El usuario deberá:

- Buscar ROS recibido.
- Revisar resumen del caso.
- Validar completitud documental.
- Clasificar riesgo.
- Solicitar subsanación si aplica.

Escenario 3 — Subsanación documental

El sujeto obligado deberá:

- Recibir solicitud de subsanación.
- Identificar documento observado o pendiente.
- Reemplazar o cargar el archivo faltante.
- Enviar corrección.

Escenario 4 — Restricciones de acceso

Se probará:

- Que un sujeto obligado no vea ROS de otra entidad.
- Que un analista solo acceda a datos permitidos.
- Que las exportaciones requieran autorización.

Métricas evaluadas

- Tiempo para registrar un ROS.
- Tiempo para revisar un expediente.
- Cantidad de errores por usuario.
- Documentos cargados correctamente.
- Solicitudes de subsanación comprendidas.
- Nivel de satisfacción de usuarios.
- Estabilidad bajo usuarios concurrentes.

Criterios de aceptación

La fase beta será exitosa si:

- Los usuarios completan las tareas principales sin asistencia constante.
- No se detectan errores críticos de seguridad o privacidad.
- La carga documental individual resulta comprensible.
- La UAF puede revisar y priorizar ROS con facilidad.
- El sistema mantiene estabilidad y tiempos de respuesta aceptables.

5.3. Pruebas UX

Las pruebas UX evaluarán la facilidad de uso tanto del portal público como de la vista interna UAF. El objetivo es reducir errores humanos, evitar saturación visual y asegurar que los usuarios comprendan claramente el flujo del sistema.

Objetivos de las pruebas UX

- Evaluar claridad del portal público.
- Validar que el formulario dinámico sea comprensible.
- Reducir errores al cargar documentos.
- Comprobar que la vista UAF sea limpia e intuitiva.
- Medir facilidad para buscar, priorizar y revisar ROS.
- Verificar claridad de mensajes de error, validación y subsanación.

Elementos evaluados

Navegación del sistema

Se evaluará:

- Menú lateral.
- Acceso a portal público y vista UAF.

- Claridad de botones.
- Ubicación de acciones principales.

Formulario dinámico ROS

Se validará:

- Comprensión de campos.
- Cambio correcto según plantilla.
- Claridad de validación de identidad.
- Carga documental por contenedor individual.
- Mensajes de documentos pendientes o cargados.

Vista interna UAF

Se verificará:

- Bandeja de ROS.
- Indicadores de riesgo.
- Resumen de expediente.
- Pestañas de riesgo, documentos y auditoría.
- Acciones de subsanación y validación.

Flujo operativo

Se comprobará:

- Facilidad para registrar ROS.
- Facilidad para revisar documentos.
- Rapidez para localizar expedientes.
- Claridad al solicitar subsanación.
- Comprensión de datos enmascarados.

Metodología de evaluación UX

Las pruebas UX se realizarán mediante:

- Observación directa.
- Tareas guiadas.
- Encuestas de satisfacción.
- Medición de tiempos.
- Registro de errores frecuentes.
- Revisión de comentarios de usuarios.

Indicadores UX

- Tiempo para completar tareas.
- Número de errores por tarea.
- Cantidad de campos abandonados.
- Nivel de satisfacción.
- Facilidad de aprendizaje.
- Claridad visual.
- Comprensión de mensajes.

Resultados esperados

El sistema deberá:

- Ser fácil de usar para sujetos obligados y usuarios UAF.
- Mostrar formularios claros y adaptados por plantilla.

- Reducir errores de carga documental.
- Evitar contaminación visual en la vista interna.
- Presentar mensajes claros en español.
- Permitir completar las tareas principales sin capacitación avanzada.

VI. Matriz de Defectos

6.1 Descripción de defectos detectados

Los defectos se clasifican según su severidad en cuatro niveles: **Crítico**, **Alto**, **Medio** y **Bajo**. Esta matriz se enfoca en errores técnicos probables durante el desarrollo del sistema, especialmente en autenticación, formularios dinámicos, carga documental, validaciones, auditoría, seguridad y sincronización entre el portal público y la vista interna de la UAF.

ID	Módulo	Descripción del defecto	Severidad	RF/RNF relacionado	CU relacionado
DEF-01	Autenticación MFA	El código MFA siempre falla porque el servidor y el dispositivo del usuario tienen horas diferentes y no existe tolerancia de tiempo.	Crítico	RNF-01 / RF-05	CU-05
DEF-02	Autenticación MFA	El sistema acepta códigos MFA vencidos porque no valida correctamente la ventana de expiración del token.	Crítico	RNF-01 / RF-05	CU-05
DEF-03	Autenticación	El sistema permite iniciar sesión sin completar MFA después de validar usuario y contraseña.	Crítico	RNF-01 / RF-05	CU-05
DEF-04	Sesión de usuario	La sesión no expira correctamente después de inactividad, permitiendo acceso desde una sesión abandonada.	Alto	RNF-01	CU-05
DEF-05	Control de acceso	Un sujeto obligado puede acceder a ROS registrados por otra entidad modificando el ID en la URL.	Crítico	RF-05 / RNF-01	CU-05
DEF-06	Roles y permisos	El frontend oculta botones, pero el backend no valida permisos antes de ejecutar acciones sensibles.	Crítico	RF-05 / RNF-01	CU-05
DEF-07	Formulario dinámico	El sistema carga una plantilla ROS incorrecta porque el tipo de sujeto obligado no se mapea correctamente.	Alto	RF-01 / RNF-03	CU-01 / CU-06
DEF-08	Formulario dinámico	Al cambiar de tipo de sujeto obligado, quedan campos antiguos en memoria y se envían datos que no corresponden a la nueva plantilla.	Alto	RF-01 / RNF-06	CU-01
DEF-09	Validación de identidad	Al verificar una cédula/RUC existente, el sistema autocompleta datos personales sensibles en el portal público.	Crítico	RF-06 / RNF-01	CU-01
DEF-10	Validación de identidad	El sistema muestra “persona no encontrada” por errores de formato, aunque la cédula existe con guiones, espacios o ceros iniciales.	Medio	RF-06 / RNF-06	CU-01
DEF-11	Validación de identidad	La verificación del ordenante y beneficiario usa el mismo estado interno, provocando que el nombre de uno sobrescriba al otro.	Alto	RF-06	CU-01
DEF-12	Registro de ROS	El sistema genera números de ROS duplicados cuando dos usuarios envían reportes al mismo tiempo.	Crítico	RF-01	CU-01
DEF-13	Registro de ROS	El botón “Enviar ROS” puede presionarse varias veces y crea reportes duplicados.	Alto	RF-01	CU-01
DEF-14	Registro de ROS	Si ocurre un error al guardar documentos, el ROS queda registrado sin evidencia y sin estado de advertencia.	Alto	RF-01 / RF-07	CU-01 / CU-08

DEF-15	Carga documental	Un archivo se guarda en el contenedor equivocado porque el identificador del documento requerido no se envía correctamente.	Alto	RF-07	CU-08
--------	------------------	---	------	-------	-------

6.2 Impacto de los defectos

Los defectos se agrupan según su impacto técnico, operativo, legal y de seguridad.

Defectos de impacto crítico — Seguridad, privacidad e integridad

Los defectos **DEF-01, DEF-02, DEF-03, DEF-05, DEF-06, DEF-09, DEF-12, DEF-16, DEF-28, DEF-31, DEF-32, DEF-33, DEF-36 y DEF-38** representan riesgos críticos para SAGAF.

Estos defectos pueden permitir accesos no autorizados, exposición de datos personales, generación de ROS duplicados, pérdida de trazabilidad, carga de archivos peligrosos o creación de registros incompletos.

Un ejemplo crítico es **DEF-01**, donde el MFA falla porque el servidor y el cliente tienen horas diferentes. En sistemas que usan códigos temporales, como OTP, la sincronización horaria es fundamental. Si el servidor está desfasado, los códigos generados por el usuario nunca coincidirán con los esperados por el sistema.

Otro defecto grave es **DEF-09**, donde el sistema muestra información personal adicional al verificar una cédula. Esto rompe el principio definido para el portal público: solo se debe mostrar el nombre para corroboración, sin revelar dirección, actividad económica, historial, contacto u otros datos sensibles.

También es crítico **DEF-36**, porque si el sistema guarda primero el ROS y luego falla al guardar los documentos, puede quedar un expediente incompleto sin advertencia. Para evitarlo, el programador debe usar transacciones, estados de proceso o mecanismos de recuperación.

Defectos de impacto alto — Riesgo operativo y fallos de implementación

Los defectos **DEF-04, DEF-07, DEF-08, DEF-11, DEF-13, DEF-14, DEF-15, DEF-17, DEF-18, DEF-19, DEF-20, DEF-22, DEF-24, DEF-26, DEF-27, DEF-29, DEF-30 y DEF-37** afectan funcionalidades centrales del sistema.

Estos errores pueden provocar formularios incorrectos, documentos mal asociados, estados documentales inconsistentes, errores de búsqueda, cambios de riesgo sin justificación o fallos en auditoría.

Un caso importante es **DEF-15**, donde un archivo se guarda en el contenedor equivocado. Esto puede ocurrir si el frontend envía mal el identificador del documento requerido o si el backend asocia el archivo solo por posición en la lista. Para evitarlo, cada documento debe tener un identificador único y persistente.

También destaca **DEF-30**, donde la auditoría usa la hora del navegador. Esto es riesgoso porque el usuario puede tener la hora incorrecta o manipulada. La hora oficial de auditoría debe ser generada por el servidor.

Defectos de impacto medio — Calidad, rendimiento y experiencia operativa

Los defectos **DEF-10, DEF-21, DEF-23, DEF-25, DEF-34, DEF-35 y DEF-40** afectan la calidad del sistema y la eficiencia del usuario.

No siempre comprometen directamente la seguridad, pero pueden provocar errores de análisis, pérdida de datos temporales, búsquedas incompletas o reportes incorrectos.

Por ejemplo, **DEF-25** afecta la búsqueda porque no normaliza acentos, mayúsculas o guiones. Esto puede hacer que una cédula o nombre exista en el sistema, pero no sea encontrado por pequeñas diferencias de formato.

Otro caso es **DEF-35**, donde los montos se guardan como texto. Esto puede causar errores al ordenar, filtrar, sumar o generar reportes financieros.

Defectos de impacto bajo — Usabilidad y presentación

Los defectos **DEF-39** y otros errores menores de interfaz no comprometen directamente la seguridad, pero afectan la experiencia de uso.

Un mensaje de error como “Error inesperado” no ayuda al sujeto obligado ni al analista. El sistema debe indicar claramente qué campo, documento o acción necesita corrección.

Conclusión del impacto

La matriz evidencia que los riesgos principales de SAGAF no están solo en la lógica de negocio, sino también en detalles técnicos de implementación. Las áreas más delicadas son:

- Sincronización horaria para MFA.
- Validación real de permisos en backend.
- Protección de datos personales en el portal público.
- Asociación correcta entre documento requerido y archivo cargado.
- Uso de transacciones al registrar ROS y documentos.

- Auditoría con hora del servidor.
- Validación segura de archivos.
- Exportaciones controladas y enmascaradas.
- Manejo correcto de formularios dinámicos por plantilla.

Estos defectos deben priorizarse durante pruebas alfa, revisión de código y pruebas de seguridad, porque pueden afectar directamente la confiabilidad, legalidad y operación del sistema.

Bibliografía

- Asamblea Nacional de Panamá. (2015). *Ley 23 de 27 de abril de 2015, que adopta medidas para prevenir el blanqueo de capitales, el financiamiento del terrorismo y el financiamiento de la proliferación de armas de destrucción masiva*. Panamá: Gaceta Oficial Digital.
- Asamblea Nacional de Panamá. (2019). *Ley 81 de 26 de marzo de 2019 sobre protección de datos personales*. Panamá: Gaceta Oficial Digital.
- CloudFlare. (2018). *¿Qué es Transport Layer Security? | Protocolo TLS*. Obtenido de Cloudflare.com: <https://www.cloudflare.com/es-es/learning/ssl/transport-layer-security-tls/>
- Grupo de Acción Financiera Internacional. (2023). *Recomendaciones del GAFI: Estándares internacionales sobre la lucha contra el lavado de activos, el financiamiento del terrorismo y el financiamiento de la proliferación*. GAFI.
- Microsoft. (2026). *Autenticación multifactor (MFA) | Seguridad de Microsoft*. Obtenido de Microsoft.com: <https://www.microsoft.com/es-es/security/business/identity-access/microsoft-entra-mfa-multi-factor-authentication>
- Progress. (11 de 6 de 2022). *Why You Should Use AES 256 Encryption to Secure Your Data*. Obtenido de Progress Blogs: <https://www.progress.com/blogs/use-aes-256-encryption-secure-data>
- Unidad de Análisis Financiero. (2018). *Manuales Calidad de ROS*. Obtenido de Uaf.gob.pa: <https://www.uaf.gob.pa/Manuales-Calidad-de-ROS/3>